

artifact-3-security-compliance-posture.md

Security and Compliance Posture

1. Summary

The platform processes sensitive customer documents: invoices, contracts, forms, and corporate reports. These documents can contain personal data, financial identifiers, legal terms, tax IDs, signatures, emails, addresses, and confidential business information.

The security posture is built around five principles:

- Tenant isolation is enforced everywhere.
- Customer content is encrypted with tenant-scoped keys.
- Immutable audit and GDPR erasure are reconciled by keeping audit records PII-free.
- Model output is treated as untrusted and cannot decide security, billing, retention, routing, or delivery behavior.

2. Case Study Interpretation and Scope

The case study asks for GDPR and SOC 2 alignment, KMS encryption, 365-day retention, automatic PII detection/masking, X-Ray tracing, and operational evidence through CI/CD and canary controls.

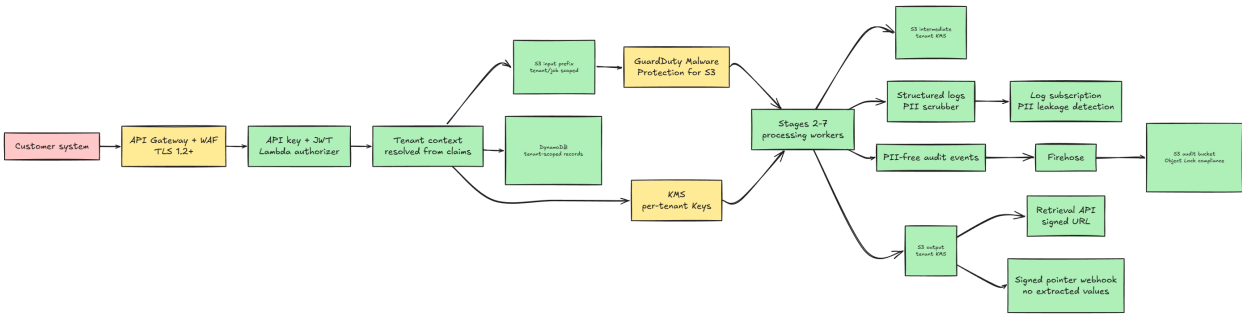
This artifact covers:

- Authentication and authorization.
- Tenant isolation.
- KMS encryption.
- S3 bucket policies and TLS.
- PII-safe logging.
- Immutable audit.
- GDPR access and erasure.
- SOC 2 evidence.

3. Security Assumptions

Area	Assumption
Tenancy	All data, keys, quotas, schemas, prompts, jobs, and metrics are tenant-scoped.
Identity	Customer API calls use API key plus short-lived signed JWT bearer token.
JWT issuer	JWTs are issued by the platform identity service backed by Cognito or an approved OIDC IdP.
Data residency	Primary region is us-east-1 ; cross-region processing is deferred until residency requirements are known.
Encryption	Customer document data uses per-tenant KMS Keys. Audit storage uses a separate platform-managed KMS boundary.
Audit	Immutable audit records are operational facts only and must not contain raw PII, document text, filenames, extracted values, or presigned URLs.
Retention	Inputs and final outputs are retained for 365 days by default; original inputs move to cold storage after 7 days.
Logs	Logs are structured, scrubbed at emit time, and inspected for leakage after emission.
Webhooks	Customers use pre-registered webhook endpoints only. Payloads are pointer-only and signed.
Model path	OCR text and prompts are treated as sensitive and untrusted. Bedrock Guardrails are mandatory for model calls.

4. Security Architecture



Security is layered:

Layer	Primary control
API edge	WAF, TLS 1.2+, API key, signed JWT, authorizer.
Tenant context	Tenant resolved from credential claims
Storage	Tenant/job-scoped S3 keys, block public access, SecureTransport deny, tenant Keys.
Processing	Least-privilege IAM, encryption context, tenant/job prefix checks, deterministic artifact contracts.
Model use	Guardrails, prompt injection controls, schema-constrained output, citation validation.
Logs	Emit-time scrubbing and post-emission leakage detection.
Audit	PII-free EventBridge to Firehose to S3 Object Lock compliance mode.
Delivery	Signed URLs from authenticated API, HMAC-signed pointer webhooks.

5. Compliance Traceability

Requirement	Control
Encrypt data at rest using KMS Keys	Inputs, intermediates, prompts, model outputs, final outputs, review artifacts, and poison diagnostics are encrypted using tenant Keys.
Encrypt data in transit	API Gateway TLS 1.2+, S3 aws:SecureTransport deny, HTTPS-only webhooks, AWS service TLS.
365-day retention	Stage 7 lifecycle policy retains original inputs and final outputs for 365 days by default; inputs cold-tier after 7 days.
Separate input/intermediate/output/audit storage	Separate buckets/prefixes and policies for original input, intermediate artifacts, durable output, and immutable audit.
Least-privilege IAM	Processing roles are scoped to tenant/job prefixes, KMS key conditions, and required service actions.

Requirement	Control
Automatic PII masking in logs	Structured logger scrubs email, SSN-like values, phone numbers, access tokens, presigned URLs, and filenames before emission.
PII leakage detection	CloudWatch Logs subscription filter routes suspicious logs to Comprehend-backed inspection Lambda.
Redacted outputs	Stage 6 creates <code>customer-result.json</code> according to tenant output policy; full result remains access-controlled.
GDPR access	Stage 7 retrieval index maps tenant/job to retained artifacts for access and export workflows.
GDPR erasure	Deletion workflow removes customer content objects, indexes, unsafe webhook payload records, and can crypto-shred through tenant key deletion where contractually allowed.
Immutable audit	Audit events go through EventBridge and Firehose to S3 Object Lock in compliance mode.
SOC 2 change management	CDK Python, GitHub Actions, tests, CDK synth, security checks, canary, rollback evidence.
Customer data access logs	Retrieval API and operator/support access emit PII-free audit events with actor, tenant, job, purpose, timestamp, and artifact hash.
Multi-tenant isolation	Tenant-scoped KMS, S3 prefixes, DynamoDB keys, prompt/schema registry, quotas, cost ledger, metrics, and authorization checks.
X-Ray tracing	Correlation ID, tenant ID, job ID, chunk ID, and stage propagated through asynchronous boundaries.

6. Tenant Isolation

Tenant isolation is enforced at every layer:

Layer	Isolation mechanism
API	Authorizer resolves tenant and scopes every request.
S3	Tenant/job-scoped keys; platform-generated object keys; block public access.
KMS	Per-tenant Keys for customer document data and derived artifacts.
DynamoDB	Job IDs as high-cardinality primary keys; tenant indexes are sharded; all reads verify tenant ownership.
Prompts/schemas	Tenant schema registry and prompt policy are scoped by tenant/schema/version.
Quotas	Token buckets and concurrency counters are tenant-scoped.
Webhooks	Jobs reference pre-registered <code>webhook_id</code> ; arbitrary URLs are not accepted in v1.
Metrics/cost	Cost, quality, and operational metrics are attributed per tenant without using raw tenant IDs as high-cardinality metric dimensions.

Per-tenant Keys is the core boundary. IAM alone is not sufficient for a SaaS platform that must support GDPR erasure and strong tenant separation.

7. PII Protection

PII controls are preventive and detective.

Preventive controls:

- Do not log raw document text.
- Do not log extracted field values.
- Do not log original filenames because filenames often contain PII.
- Do not log presigned URLs.
- Do not put raw PII in immutable audit.
- Redact customer-facing output according to tenant policy.
- Keep webhook payloads pointer-only.

Detective controls:

- Structured logging library scrubs likely PII before logs leave the process.
- CloudWatch Logs subscription filter inspects log streams for leakage.
- Comprehend-backed detection flags emails, SSNs, and similar sensitive patterns.

- `pii_log_detection_count` and alerting drive incident response.

Redaction behavior:

- Validation runs before redaction.
- Redaction failure blocks delivery.
- Fields without explicit redaction policy flow through unchanged.
- Fields with policy are masked, suppressed, or value-hidden.
- Full unredacted result stays only in access-controlled internal artifact.

8. Immutable Audit and GDPR Erasure

SOC 2 wants durable audit evidence. GDPR requires deletion of customer content. Therefore, audit records must not contain customer content.

Audit path:

Application audit event -> EventBridge -> Firehose -> S3 audit bucket with Object



GDPR erasure workflow:

1. Mark job `DELETION_REQUESTED` .
2. Stop processing, replay, and webhook delivery for the job.
3. Delete input, intermediate, final, and customer output artifacts from their respective S3 buckets.
4. Delete retrieval index entries and any webhook delivery payload records that contain customer content beyond audit-safe IDs.
5. Crypto-shred tenant data when contract and legal hold allow: disabling or scheduling deletion of the tenant KMS Keys makes all encrypted artifacts unreadable without requiring individual object deletion at scale.
6. Mark job `DELETED` .
7. Keep PII-free immutable audit record as security evidence — this record contains no customer content and is explicitly excluded from erasure scope.

9. Model Security

OCR text and customer documents are untrusted input. The model must not be able to control infrastructure decisions.

Model safeguards:

- Bedrock Guardrails are mandatory for v1 model invocations.

- Prompt injection instructions inside documents are treated as data, not commands.
- Prompt package excludes secrets, auth material, original PII-bearing filenames, and unrelated tenant content.
- Free-form output is ignored and treated as invalid.
- Every non-null extracted value must cite source spans.
- Missing or invalid citations reject the field.

Few-shot retrieval:

- Tenant-scoped examples are preferred.
- Platform-curated examples must be PII-free.

10. SOC 2 Evidence Model

SOC 2 concern	Evidence produced
Change management	GitHub Actions runs tests, coverage, security checks, CDK synth, and canary rollout records.
Access control	IAM policies, API authorizer logs, operator access audit events, support reason codes.
Encryption	KMS key policies, S3 encryption config, object metadata validation.
Availability	SLO dashboards, incident records, DLQ/replay history, provider outage runbooks.
Processing integrity	Artifact hashes, state transitions, schema/prompt/model versions, citation validation outcomes.
Confidentiality	PII-safe logs, tenant Keys use, webhook pointer-only payloads, redaction policy evidence.
Privacy	GDPR access/deletion workflow records, retention lifecycle config, PII-free audit separation.